

TECHNICAL DETAIL

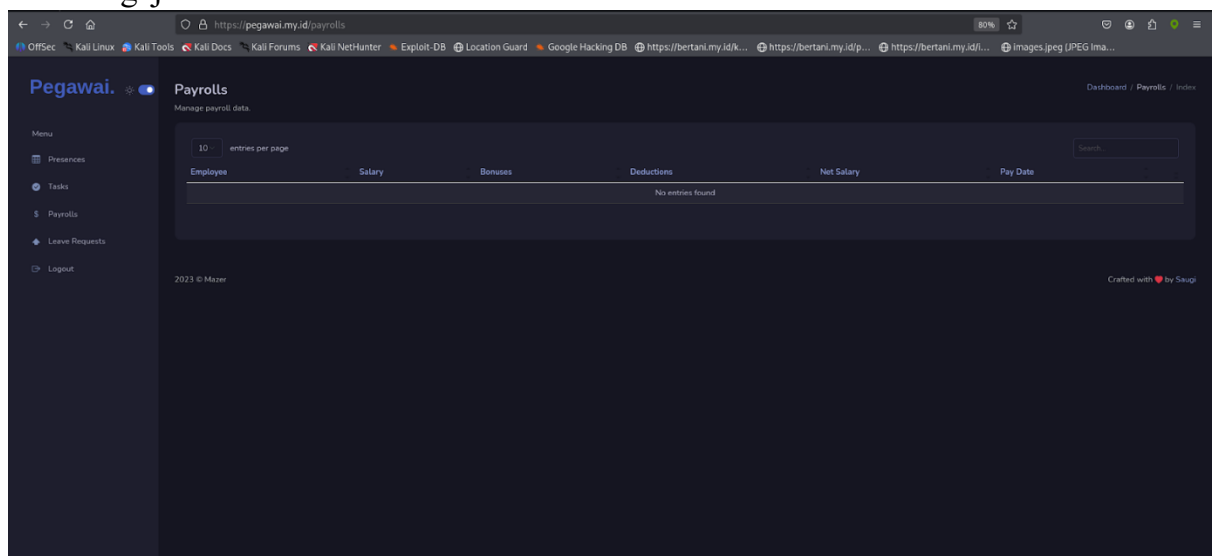
Title	Broken Access Control: Insecure Direct Object Reference (IDOR) on Payroll Details
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/payrolls/{id}
Severity	Medium
CVSS Score	6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

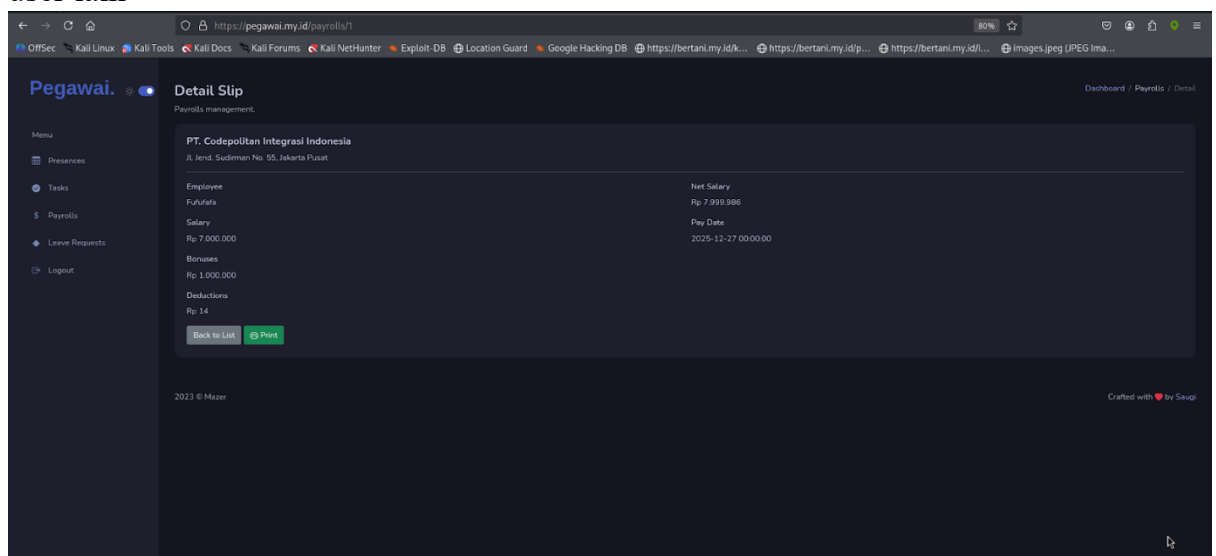
Ditemukan kerentanan Broken Access Control berjenis Insecure Direct Object Reference (IDOR) pada fitur rincian slip gaji (*Payroll Details*) di platform pegawai.my.id. Kerentanan ini memungkinkan pengguna yang sudah masuk (misalnya peran *Developer*) untuk melihat detail slip gaji milik karyawan lain hanya dengan mengubah parameter ID pada URL. Hal ini mengakibatkan kebocoran informasi finansial pribadi yang seharusnya bersifat sangat rahasia.

STEPS TO REPRODUCE

1. Login ke akun Anda yang memiliki role developer
2. Buka url <https://pegawai.my.id/payrolls> disini terlihat tidak ada fitur untuk melihat gaji user lain



3. Lalu tambahkan `/payrolls/{id}` dalam contoh kali ini saya masukan 1 maka di url menjadi `https://pegawai.my.id/payrolls/1` maka anda bisa melihat slip milik user lain



EXPECTED RESULT

Akses ke rincian slip gaji tertentu (/payrolls/{id}) seharusnya dibatasi hanya untuk pemilik slip gaji tersebut atau staf keuangan yang berwenang. Pengguna yang mencoba mengakses ID milik orang lain tanpa wewenang administratif seharusnya menerima respons 403 Forbidden.

ACTUAL RESULT

Aplikasi mengizinkan akses ke rincian slip gaji siapa pun hanya melalui manipulasi ID di URL tanpa melakukan pengecekan otorisasi di sisi server terhadap kepemilikan data tersebut. Penyerang dapat melihat data sensitif seperti nominal gaji bersih, tanggal pembayaran, hingga rincian potongan karyawan lain.

IMPACT

1. **Privacy Violation:** Pelanggaran privasi berat melalui paparan data finansial pribadi karyawan.
2. **Financial Information Disclosure:** Kebocoran struktur penggajian internal perusahaan yang dapat memicu konflik internal atau disalahgunakan oleh pihak luar.

RECOMMENDATION

1. **Object-Level Authorization:** Implementasikan pengecekan otorisasi pada fungsi show di dalam *Payroll Controller* untuk memastikan ID slip gaji yang diminta adalah milik pengguna yang sedang login.
2. **Implementasi Kebijakan Otoritas (Policy):** Gunakan fitur *Policies* di Laravel untuk mendefinisikan siapa saja yang boleh melihat rincian penggajian tertentu

REFERENCES

1. **OWASP Top 10 - A01:2021 Broken Access Control:**
https://owasp.org/Top10/A01_2021-Broken_Access_Control/
2. **CWE-639: Authorization Bypass Through User-Controlled Key:**
<https://cwe.mitre.org/data/definitions/639.html>

